



**BLUE TEAM
LABS ONLINE**
Powered by Security Blue Team

RESOLUCIÓN DE LABORATORIO

Lab: ATT&CK (BTLO)

Aplicación práctica del framework MITRE ATT&CK para mapear tácticas, técnicas y grupos APT en escenarios reales de amenaza, identificando vectores de acceso inicial, comunicación C2, impacto y métodos de detección.

Escenario:

You are hired as a Blue Team member for a company. You are assigned to perform threat intelligence for the company. See how you can operationalize the MITRE ATT&CK framework to solve these scenario-based problems.

Herramientas utilizadas:

- Mitre ATT&CK
- Wayback Machine

P1: Your company heavily relies on cloud services like Azure AD, and Office 365 publicly. What technique should you focus on mitigating, to prevent an attacker performing Discovery activities if they have obtained valid credentials? (Hint: Not using an API to interact with the cloud environment!)

R: T1538

El escenario se mapeó correctamente en la táctica de Discovery. Debido a que se especificó que el atacante no utilizará una API para interactuar con el entorno, esto indica que usará las credenciales comprometidas para autenticarse como un usuario normal a través del navegador. Este comportamiento corresponde a la técnica Cloud Service Dashboard (T1538), la cual describe cómo un adversario aprovecha la interfaz gráfica del servicio en la nube con credenciales robadas, para explorar y obtener información crítica del entorno.

The screenshot shows the MITRE ATT&CK website interface. The top navigation bar includes links for Matrices, Tactics, Techniques, Defenses, CTI, Resources, Benefactors, Contribute, and Blog. A search bar is also present. Below the navigation bar, a banner announces ATT&CKcon 7.0. The main content area is titled 'Cloud Service Dashboard' and includes a breadcrumb trail: Home > Techniques > Enterprise > Cloud Service Dashboard. The page describes how an adversary might use a cloud service dashboard GUI with stolen credentials to gain information from an operational cloud environment. It also mentions that depending on the configuration, an adversary might be able to enumerate more information via a graphical dashboard than an API. On the right side, a metadata box lists the ID (T1538), sub-techniques (None), tactic (Discovery), platforms (IaaS, Identity Provider, Office Suite, SaaS), contributors (Obsidian Security, Praetorian), version (1.5), creation date (30 August 2019), and last modified date (24 October 2025). A left sidebar lists various techniques under the 'TECHNIQUES' category, with 'Cloud Service Dashboard' highlighted.

P2: You were analyzing a log and found uncommon data flow on port 4050. What APT group might this be?

R: G0099

El escenario actual detalla un flujo de datos sospechoso por el puerto 4050, lo que indica una fuga o inyección de datos (comandos) mapeado en la táctica de Command and Control. El puerto 4050 es un puerto no estándar o no asignado por IANA a algún servicio. La técnica Non-Standard Port (T1571) describe el uso de estos puertos para la comunicación de los adversarios. Dentro de los ejemplos de

procedimientos, se detalla como el grupo APT-C-36 (G0099) utilizó el puerto 4050 para comunicación C2.

MITRE | ATT&CK®

Matrices ▼ Tactics ▼ Techniques ▼ Defenses ▼ CTI ▼ Resources ▼ Benefactors Contribute Blog ↗

Search 🔍

TECHNIQUES

Enterprise
Reconnaissance
Resource Development
Initial Access
Execution

Procedure Examples

ID	Name	Description
C0063	2025 Poland Wiper Attacks	During the 2025 Poland Wiper Attacks, the adversaries had created a Reverse SOCKS Proxy and communicated over the non-standard port 8008. ^{[4][5]}
G0099	APT-C-36	APT-C-36 has used port 4050 for C2 communications. ^[6]

P3: The framework has a list of 9 techniques that falls under the tactic to try to get into your network. What is the tactic ID?

R: TA0001

La táctica enfocada en los intentos de intrusión a la red corporativa se denomina Initial Access y está registrada bajo el ID TA0001. Actualmente, 27 de Mayo del 2026, la matriz cuenta formalmente con 11 técnicas mapeadas dentro de esta columna

MITRE | ATT&CK®

Matrices ▼ Tac

Search 🔍

Reconnaissance
12 techniques

Resource Development
9 techniques

Initial Access
11 techniques

Initial Access

The adversary is trying to get into your network.

Initial Access consists of techniques that use various entry vectors to gain their initial foothold within a network. Techniques used to gain a foothold include targeted spearphishing and exploiting weaknesses on public-facing web servers. Footholds gained through initial access may allow for continued access, like valid accounts and use of external remote services, or may be limited-use due to changing passwords.

ID: TA0001

Created: 17 October 2018

Last Modified: 25 April 2025

Version Permalink

P4: A software prohibits users from accessing their account by deleting, locking the user account, changing password etc. What such software has been documented by the framework?

R: S0372

El escenario descrito detalla una pérdida de disponibilidad provocada por un software que elimina o restringe de forma maliciosa el acceso a las cuentas de usuario. Este comportamiento se mapea con precisión bajo la táctica de Impact mediante la técnica Account Access Removal (T1531), la cual recopila acciones orientadas a eliminar, bloquear o manipular las credenciales de identidad. Como evidencia de este procedimiento en escenarios reales, el framework de ciberseguridad documenta que el ransomware LockerGoga (S0372) ejecuta este mismo patrón de ataque, modificando las contraseñas de los usuarios para sabotear el inicio de sesión.

MITRE ATT&CK®			
Search			
Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾ Benefactors Contribute Blog			
TECHNIQUES			
S0372	LockerGoga	LockerGoga has been observed changing account passwords and logging off current users. ^{[2][3]}	

P5: Using ‘Pass the Hash’ technique to enter and control remote systems on a network is common. How would you detect it in your company?

R: Monitor newly created logons and credentials used in events and review for discrepancias

Debido a las múltiples actualizaciones estructurales que ha tenido el framework de MITRE ATT&CK desde la creación de este laboratorio, se utilizó la herramienta Wayback Machine para auditar el estado del sitio web con fecha exacta del 18 de septiembre de 2022. Bajo este contexto histórico, el análisis de la subtécnica Pass the Hash (T1550.002), la cual describe el uso del hash de una contraseña para autenticarse sin requerir el texto plano, contemplaba un método de detección centrado en el componente Logon Session. Este describía explícitamente que la organización debe monitorear los inicios de sesión recién creados y las credenciales utilizadas en dichos eventos para identificar y revisar posibles discrepancias en el comportamiento de la red.

Internet Archive Wayback Machine 155 captures 9 Aug 2020 - 3 May 2023			
https://attack.mitre.org/techniques/T1550/002/			
Go AUG SEP NOV 2021 2022 2023 About this capture			
MITRE ATT&CK®			
Contribute Search			
Matrices ▾ Tactics ▾ Techniques ▾ Data Sources ▾ Mitigations ▾ Groups ▾ Software ▾ Resources ▾ Blog			
TECHNIQUES			
Evasion			
Weakens Encryption	▾	DS0028	Logon Session
XSL Script Processing	▾	Logon Session	Creation
Credential Access	▾	ticket was requested) combined with logon session creation information may be indicative of an overpass the hash attempt.	
		Monitor newly created logons and credentials used in events and review for discrepancies. Unusual remote logins that correlate with other suspicious activity (such as writing and executing binaries) may indicate malicious activity.	